

PHISHING EMAIL ANALYSIS

By: Patrick Ofori-Sampong

Scenario:

Your email address has been leaked and you receive an email from Paypal in German. Try to analyze the suspicious email.

Objective:

Analyze a suspicious PayPal email (in German) received after an email address leak. Determine if the email is a phishing attempt by investigating its metadata, embedded links, and message body.

Tools Used:

- Microsoft Outlook (to open .eml file)
- Manual header analysis
- URL/domain inspection tools: VirusTotal,

Steps Taken:

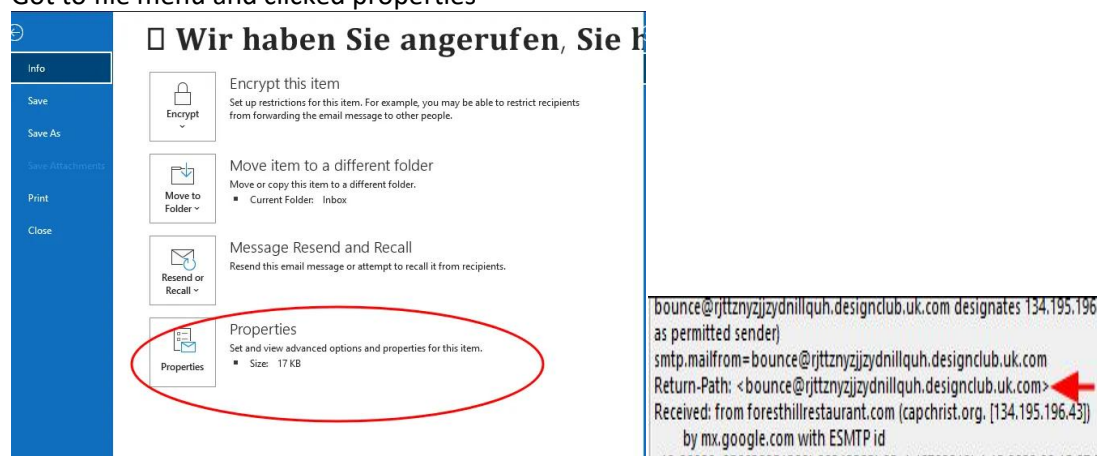
- Extracted the challenge file: PhishingChallenge.zip (password: infected).
- Opened the .eml file in Microsoft Outlook to review headers and content.

Challenge 1:

What is the return path of the email?

The return path is the email address where replies are directed, which can differ from the original sender.

Got to file menu and clicked properties



By analyzing the email headers through the file properties, I identified the return path. Although the SMTP IP and domain reputation appeared clean, no official PayPal domains were present in the header. This strongly suggests a newly launched phishing campaign, as legitimate PayPal emails would always reference PayPal-owned domains.

Answer : bounce@rjttznzyjzydnillquh.designclub.uk.com

Challenge 2:

What is the domain name of the url in this mail?

Inspecting the email body revealed a large button meant to redirect the recipient. By hovering over the button (without clicking), I extracted the destination URL embedded in the message.

PayPal.com

Hello!

You are customer no. 12819202501 of AU PayPal Rewards and we have been waiting for your confirmation since 09.08.2022. This delivery is for you. To activate the delivery, [please confirm](#).

Your account information

Could: Krystyalia

Email: Krystyalia@https://storage.googleapis.com/hqyqzqtqth/aemmfcyhxco.htmimQORhNZC44FT4.QORhNZC44FT4?dYCTyuccar3jcxamcdckBdmCSD6qfJvcbbb4M

Reward: [PayPal pre](#)

Click or tap to follow link.

[Continue delivery](#)

The extracted URL shows a Google API domain, which at first glance appears legitimate. Verified the domain on VirusTotal and Cisco Talos, both of which confirmed it as a trusted service.

On closer inspection, the button redirects to a Google API subdomain with randomized path names, which is unusual. I Copied the entire URL and submitted it to VirusTotal. The scan returned multiple security hits, confirming malicious activity.

Likely scenario: the attacker leveraged a subdomain takeover or gained persistence on the subdomain. This technique, known as a DNS shadowing attack, allows threat actors to abuse a legitimate domain (e.g., Google API) for their phishing campaign.

https://storage.googleapis.com/hqyqzqtqth/aemmfcyhxco.html

4 / 91

4 security vendors flagged this URL as malicious

https://storage.googleapis.com/hqyqzqtqth/aemmfcyhxco.html

200 Status 2022-12-04 08:43:43 UTC 7 hours ago

DETECTION DETAILS COMMUNITY 14

Security Vendors' Analysis

Vendor	Detection	Category	Status
0xSI_D3d	Phishing	Fortnet	Phishing
Netcraft	Malicious	Webroot	Malicious
ESET	Suspicious	Abusix	Clean

Answer : storage.googleapis.com

Challenge 3:

Is the domain mentioned in the previous question suspicious?

Checked the subdomain (without the full path) on VirusTotal.

https://storage.googleapis.com/

1 / 91

1 security vendor flagged this URL as malicious

https://storage.googleapis.com/

storage.googleapis.com

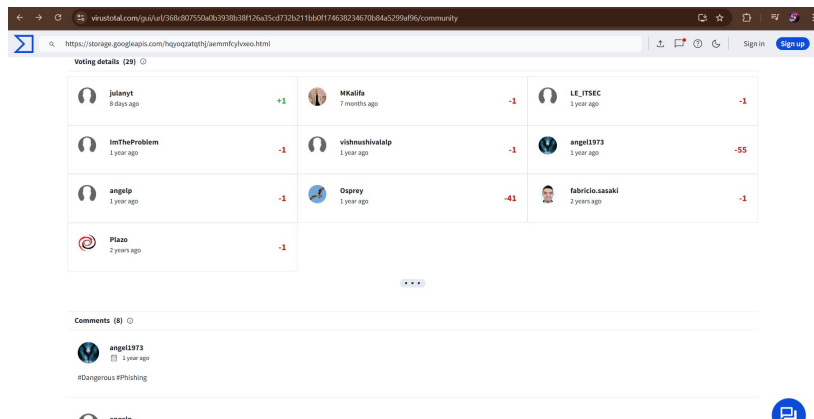
DETECTION DETAILS COMMUNITY 20 +

Security Vendors' Analysis

Vendor	Detection	Category	Status
0xSI_D3d	Phishing	Fortnet	Phishing

Only 1 detection was flagged, which could be a false positive.

However, after reviewing community comments and feedback, it became clear that the domain has been repeatedly linked to phishing campaigns.



Conclusion: despite low AV detections, community intelligence confirms the domain is suspicious.

Answer : yes

Challenge 4:

What is the body SHA-256 of the domain?

Submitted the suspicious domain to VirusTotal for full analysis.

Navigated to the Details tab of the report.

Located the SHA-256 hash value associated with the scanned domain's body.

This unique hash can be used as an indicator of compromise (IoC) for detection and threat intelligence sharing.

<https://storage.googleapis.com/>

108.177.111.128
Status Code
400
Body Length
181 B
Body SHA-256
13945ecc33afee74ac7f72e1d5bb73050894356c4bf63d02a1a53e76830567f5

Answer : 13945ecc33afee74ac7f72e1d5bb73050894356c4bf63d02a1a53e76830567f5

Challenge 5:

Is this email a phishing email?

Based on the evidence collected from header analysis, URL inspection, and VirusTotal results, the email is confirmed to be phishing.

Indicators include:

No official PayPal domains in the header.

Suspicious subdomain usage with randomized paths.

VirusTotal detections and community reports linking the domain to phishing campaigns.

Answer: Yes, this is a phishing email.